

Access Control Policy

Organization: OutFront Data — a financial-insights software product operated by Makers' House LLC

Policy owner: Sean Austin (Founder) — seanaustin1@gmail.com

Effective date: 2026-06-15

Version: 1.0

Review cadence: At least annually, and after any material change or security incident.

This policy is a companion to, and consistent with, the OutFront Data Information Security Policy.

1. Purpose & Scope

This policy defines how access to production systems and sensitive data is granted, authenticated, restricted, reviewed, and revoked. It applies to all personnel, contractors, automated services, code, and third-party platforms used to deliver the product.

2. Guiding Principles

- **Least privilege** — each person or service receives only the access required to perform its function, and no more.
- **Need-to-know** — access to highly sensitive data (bank/transaction data, Plaid access tokens) is limited to systems and individuals that require it.
- **Deny by default** — access is granted explicitly; anything not granted is denied.
- **Separation of duties** where practical given organization size, with compensating monitoring controls otherwise.

3. Roles & Ownership

- The **Policy Owner** administers all access: granting, reviewing, and revoking it, and is the sole holder of privileged/administrative access to production infrastructure.
- All personnel must follow this policy and report suspected access misuse or compromise to the Policy Owner immediately.

4. End-User (Customer) Access

- Application end users authenticate through **Clerk**, our centralized identity provider.
- Authorization is enforced via **role-based access control (RBAC)** with defined roles (Operator, Manager, Consultant, Investor), each scoped to least privilege.
- **Tenant isolation** is enforced in application logic so a user can only access data belonging to their own organization.

5. Administrative / Privileged Access

- Administrative access to production platforms (**Vercel, Supabase, Clerk, Plaid, GitHub**, and any future provider such as Dwolla) is restricted to the Policy Owner.
- All such access requires **multi-factor authentication (MFA)** and strong, unique passwords stored in a password manager.
- Privileged credentials are never shared, embedded in code, or transmitted over insecure channels.

6. Authentication Requirements

- **MFA is required** for all administrative/privileged access to systems that store or process consumer financial data.
- Passwords must be strong, unique per service, and managed in a password manager.
- Where supported, phishing-resistant factors (passkeys, authenticator apps) are preferred over SMS.

7. Non-Human / Service Authentication

- Service-to-service and machine authentication uses **OAuth tokens, scoped API keys, and signing secrets** (e.g., Plaid tokens, Toast OAuth2 client credentials, Inngest signing key), not shared user accounts.
- All service connections are protected with **TLS certificates / HTTPS**.
- Service credentials and the data-encryption key are stored as **environment-variable secrets**, excluded from source control, with **separate keys for production and development**.

8. Provisioning, Review & Revocation

- **Provisioning:** access is granted by the Policy Owner on a least-privilege, need-to-know basis.
- **Review:** access and active credentials are reviewed at least annually and whenever roles or systems materially change.
- **Revocation / de-provisioning:** access is revoked promptly when no longer required (offboarding) or upon suspected compromise; affected secrets and keys are rotated.

9. Secrets & Key Management

- Credentials, API keys, and encryption keys live only in platform secret stores / local `.env` files excluded from version control (`.gitignore`).
- Secrets are rotated on offboarding or any suspected exposure and are never logged.

10. Monitoring of Access

- Authentication and access events are logged via platform tooling (Clerk authentication logs, Vercel, Supabase, Inngest), reviewed when investigating anomalies. Sensitive values are excluded from logs.

11. Governance & Review

This policy is reviewed and updated at least annually and after any major change or incident.

Version	Date	Author	Notes
1.0	2026-06-15	Sean Austin	Initial policy